



REDE HOSPITALAR CUIDAR

Projeto de Infraestrutura de Redes

RELATÓRIO TÉCNICO

Etapa 4 — Mecanismos de Segurança da Informação

Belo Horizonte, Junho de 2026
PUC Minas — Sistemas de Informação — Eixo 5

INTEGRANTES DO GRUPO

Nome	Responsabilidade na Etapa 4
Athos Geraldo	PSI e Aplicação CRUD
Pedro Gontijo	PSI e Aplicação CRUD
Bernardo	Cartilha de Boas Práticas
Henrique	Cartilha de Boas Práticas
Igor	Relatório Técnico
Fabício	Relatório Técnico

1. Introdução

Este relatório técnico documenta as entregas da Etapa 4 do Projeto de Infraestrutura de Redes da Rede Hospitalar Cuidar, desenvolvido no âmbito da disciplina de Projeto de Infraestrutura — Eixo 5 do curso de Sistemas de Informação da PUC Minas. O foco desta etapa é a segurança da informação, contemplando a análise de vulnerabilidades dos serviços e servidores configurados nas etapas anteriores, o deploy de uma aplicação back-end em ambiente de nuvem e a elaboração da Política de Segurança da Informação (PSI) da organização.

Com a infraestrutura já consolidada nas etapas anteriores — incluindo servidores locais (on-premise) com serviço de diretório, monitoramento centralizado e segmentação de rede —, esta etapa avança para a camada de proteção dos ativos de informação, elemento crítico em um ambiente hospitalar que processa dados pessoais sensíveis de pacientes.

2. Ambiente Implantado

A infraestrutura da Rede Hospitalar Cuidar é composta por um ambiente híbrido, combinando servidores on-premise e serviços em nuvem. Para a Etapa 4, a aplicação back-end foi implantada em ambos os ambientes, conforme descrito a seguir.

2.1. Ambiente Local (On-Premise)

Componente	Especificação
Sistema Operacional	Ubuntu Server 24.04 LTS
IP do Servidor	192.168.18.75 (rede local)
Banco de Dados	MySQL — banco hospital_cuidar
Aplicação	Python 3.12 + Flask 3.0.3
Porta	5000
Acesso	http://192.168.18.75:5000 (rede interna)

2.2. Ambiente em Nuvem (Cloud)

Componente	Especificação
Provedor	Amazon Web Services (AWS)
Instância	srv-app-cuidar (i-0c3eebbbc38247844)
Tipo	t2.micro — Ubuntu Server 24.04 LTS
IP Público	54.173.232.218

Banco de Dados	MySQL — banco hospital_cuidar
Aplicação	Python 3.12 + Flask 3.0.3
Porta	5000
Link de Acesso Público	http://54.173.232.218:5000
VPC	rede-cuidar-vpc

3. Aplicação Back-End — CRUD de Pacientes

Para atender ao requisito de deploy de uma aplicação back-end, foi desenvolvido um sistema de cadastro de pacientes (CRUD) utilizando o framework Flask (Python) com banco de dados MySQL. A aplicação foi implantada tanto no servidor local quanto na instância em nuvem, sendo o link público utilizado para fins de entrega e avaliação.

3.1. Funcionalidades

- Listagem de todos os pacientes cadastrados (GET /)
- Cadastro de novo paciente — nome, CPF, data de nascimento e unidade de atendimento (GET/POST /cadastrar)
- Edição de registro existente (GET/POST /editar/<id>)
- Remoção de registro com confirmação (POST /deletar/<id>)

3.2. Identidade Visual

A aplicação foi desenvolvida com identidade visual da Rede Hospitalar Cuidar, incluindo paleta de cores institucional (azul escuro #1F4E79 e azul médio #2E75B6), logotipo estilizado com ícone de cruz médica, tipografia DM Sans e Playfair Display, e rodapé identificando o projeto e a instituição de ensino.

3.3. Unidades de Atendimento Disponíveis

- Matriz — BH
- Secretaria
- UPA 1
- UPA 2
- UPA 3

3.4. Repositório

O código-fonte da aplicação está disponível no repositório do projeto no GitHub: <https://github.com/ICEI-PUC-Minas-PMV-SI/pmv-si-2026-1-pe5-t2-rede-cuidar>

4. Política de Segurança da Informação (PSI)

Foi elaborada a Política de Segurança da Informação (PSI) da Rede Hospitalar Cuidar, documento formal que estabelece as diretrizes, responsabilidades e requisitos para a proteção dos ativos de informação da organização. O documento foi desenvolvido com base no template fornecido pelo professor e nas orientações da aula inaugural da Etapa 4, seguindo as normas ABNT NBR ISO/IEC 27001, LGPD (Lei nº 13.709/2018), Marco Civil da Internet (Lei nº 12.965/2014) e Resolução CFM nº 1.821/2007.

4.1. Estrutura da PSI

A PSI foi estruturada conforme o template fornecido, contemplando as seguintes seções:

- Introdução — objetivo e escopo da política
- Princípios de Segurança — confidencialidade, integridade e disponibilidade
- Gerenciamento de Acesso — controle de acesso, autenticação e autorização
- Segurança Física e Ambiental — proteção de instalações e controle físico
- Segurança de Redes e Comunicações — proteção de redes e monitoramento
- Gestão de Incidentes de Segurança — resposta e relatórios de incidentes
- Conscientização e Treinamento — programa de conscientização e treinamento
- Avaliação e Melhoria Contínua — auditorias, revisões e análise de riscos
- Conformidade Legal e Regulatória — LGPD, ISO 27001, CFM
- Responsabilidades — direção, equipe de TI e funcionários
- Glossário e Referências

4.2. Observações sobre a PSI

Conforme orientação do professor, a PSI foi redigida em linguagem genérica e institucional, sem referência a tecnologias, produtos ou fornecedores específicos. Isso garante que o documento permaneça válido mesmo que a infraestrutura tecnológica seja alterada — por exemplo, uma migração de sistema operacional ou troca de provedor de nuvem não exigirá atualização da PSI.

5. Análise de Vulnerabilidades

Com base no ambiente implantado para hospedar a aplicação back-end da Rede Hospitalar Cuidar, foram identificadas três vulnerabilidades de segurança, classificadas segundo o OWASP Top 10 (2021). As vulnerabilidades foram analisadas considerando tanto o ambiente local (192.168.18.75:5000) quanto o ambiente em nuvem (54.173.232.218:5000).

5.1. Vulnerabilidade 1 — Injeção de SQL (SQL Injection)

Categoria	Detalhamento
Classificação OWASP	A03:2021 — Injection
Severidade	Crítica
Descrição	A aplicação recebe entradas do usuário via formulários HTML (nome, CPF, data de nascimento) e as utiliza em consultas ao banco de dados MySQL. Caso a parametrização de queries não seja corretamente implementada em todas as rotas, um agente malicioso pode inserir comandos SQL nos campos de entrada, manipulando ou extraindo dados do banco hospital_cuidar.
Contexto no Ambiente	O banco MySQL hospedado em ambos os ambientes (local e nuvem) armazena dados sensíveis de pacientes, incluindo CPF e data de nascimento — dados pessoais protegidos pela LGPD. O usuário cuidar_user possui privilégios totais sobre o banco (GRANT ALL PRIVILEGES), ampliando o impacto potencial de um ataque bem-sucedido.
Mitigação Proposta	Garantir o uso exclusivo de queries parametrizadas (prepared statements) em todas as rotas da aplicação, eliminando a concatenação direta de entradas do usuário em strings SQL. Adicionalmente, revisar os privilégios do usuário cuidar_user, aplicando o princípio do menor privilégio (somente SELECT, INSERT, UPDATE e DELETE — sem DROP ou ALTER).

5.2. Vulnerabilidade 2 — Ausência de Criptografia na Comunicação (HTTP sem TLS)

Categoria	Detalhamento
Classificação OWASP	A02:2021 — Cryptographic Failures
Severidade	Alta
Descrição	A aplicação está sendo servida pelo servidor de desenvolvimento Flask na porta 5000, sem implementação de protocolo TLS/SSL. Todo o tráfego entre o cliente (navegador) e os servidores — tanto local (192.168.18.75:5000) quanto em nuvem (54.173.232.218:5000) — trafega em texto puro via HTTP, tornando os dados suscetíveis a ataques de interceptação (Man-in-the-Middle).
Contexto no Ambiente	Os formulários da aplicação transmitem dados sensíveis de pacientes (nome completo, CPF, data de nascimento) sem

	qualquer camada de criptografia. Em um ambiente hospitalar real, isso representa violação direta da LGPD (Art. 46 — medidas de segurança) e das diretrizes do CFM para sistemas de prontuário eletrônico. No ambiente em nuvem, o risco é amplificado pois o tráfego percorre a internet pública sem proteção.
Mitigação Proposta	Implementar um proxy reverso com Nginx na porta 443, configurado com certificado TLS (via Let's Encrypt para o ambiente em nuvem ou certificado auto-assinado para o ambiente interno), redirecionando todo o tráfego HTTP para HTTPS. O servidor Flask deve ser configurado para responder somente via localhost, com o Nginx atuando como intermediário seguro.

5.3. Vulnerabilidade 3 — Ausência de Controle de Acesso e Autenticação

Categoria	Detalhamento
Classificação OWASP	A01:2021 — Broken Access Control
Severidade	Crítica
Descrição	A aplicação não implementa qualquer mecanismo de autenticação ou autorização. Qualquer dispositivo com acesso ao endereço IP e porta dos servidores consegue acessar, cadastrar, editar e remover registros de pacientes sem necessidade de credenciais. No ambiente em nuvem, isso significa que qualquer pessoa com acesso à internet e conhecimento do link público pode manipular os dados.
Contexto no Ambiente	No ambiente local, o servidor está acessível em 192.168.18.75:5000 para todos os dispositivos da rede interna segmentada (bloco 10.0.0.0/8), incluindo todas as unidades da Rede Hospitalar Cuidar. No ambiente em nuvem, o link 54.173.232.218:5000 está exposto publicamente, com a porta 5000 aberta para 0.0.0.0/0 no grupo de segurança da instância EC2. Ambos representam violação direta do princípio de confidencialidade da PSI e da LGPD.
Mitigação Proposta	Implementar autenticação baseada em sessão (Flask-Login) com credenciais individuais por perfil de acesso (médico, recepção, administrador de TI), aplicando o modelo RBAC (Role-Based Access Control) alinhado ao serviço de diretórios corporativo já implantado. Para o ambiente em nuvem, configurar as regras do grupo de segurança da EC2 para restringir o acesso à porta 5000 somente aos endereços IP autorizados, removendo a regra 0.0.0.0/0.

6. Cartilha de Boas Práticas de Acesso Seguro

Foi elaborada a Cartilha de Boas Práticas de Acesso Seguro da Rede Hospitalar Cuidar, documento visual e acessível que sintetiza as principais diretrizes da PSI em linguagem simples, destinado a todos os colaboradores da organização, independentemente de seu nível técnico.

A cartilha aborda os principais temas de segurança relevantes para o dia a dia dos colaboradores hospitalares, incluindo criação e uso seguro de senhas, identificação de tentativas de phishing e engenharia social, cuidados com o manuseio de dados de pacientes, procedimentos de reporte de incidentes e boas práticas de acesso remoto aos sistemas da rede.

7. Divisão de Tarefas entre os Integrantes

As atividades da Etapa 4 foram distribuídas entre os integrantes do grupo conforme as competências e disponibilidades de cada um, garantindo a entrega de todos os artefatos exigidos dentro do prazo estabelecido.

Integrante	Responsabilidade	Atividades Realizadas
Athos Geraldo	PSI e Aplicação CRUD	Elaboração da PSI, desenvolvimento da aplicação Flask, configuração do banco MySQL, deploy no servidor local e na instância EC2 em nuvem
Pedro Gontijo	PSI e Aplicação CRUD	Elaboração da PSI, revisão do documento, suporte ao desenvolvimento e implantação da aplicação
Bernardo	Cartilha de Boas Práticas	Elaboração e design da cartilha de boas práticas de acesso seguro para os colaboradores da Rede Hospitalar Cuidar
Henrique	Cartilha de Boas Práticas	Elaboração e revisão da cartilha de boas práticas, adequação da linguagem para o público não técnico
Igor	Relatório Técnico	Redação e estruturação do relatório técnico, documentação do ambiente implantado e análise de vulnerabilidades
Fabício	Relatório Técnico	Redação e revisão do relatório técnico, apoio na documentação das vulnerabilidades e das entregas da etapa

8. Conclusão

A Etapa 4 do Projeto de Infraestrutura de Redes da Rede Hospitalar Cuidar foi concluída com êxito, contemplando todas as entregas exigidas: a elaboração da Política de Segurança da Informação (PSI), o desenvolvimento e deploy da aplicação back-end CRUD em ambiente de nuvem, a produção da Cartilha de Boas Práticas de Acesso Seguro e a análise de vulnerabilidades do ambiente implantado.

A aplicação back-end está disponível publicamente no endereço <http://54.173.232.218:5000>, hospedada em instância Ubuntu Server na AWS, com banco de dados MySQL configurado localmente na própria instância. O ambiente local complementar está disponível em <http://192.168.18.75:5000>, ambos com o CRUD de pacientes plenamente operacional.

As três vulnerabilidades identificadas — SQL Injection, ausência de TLS e falta de autenticação — são comuns em aplicações em fase de desenvolvimento e foram documentadas com suas respectivas estratégias de mitigação baseadas no OWASP Top 10 (2021). A implementação dessas mitigações representaria um avanço significativo na postura de segurança da solução, alinhando-a às diretrizes da PSI elaborada e às exigências da LGPD para ambientes que processam dados pessoais sensíveis de pacientes.

Referências

- ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. ABNT NBR ISO/IEC 27001: Tecnologia da informação — Técnicas de segurança — Sistemas de gestão da segurança da informação — Requisitos. Rio de Janeiro: ABNT, 2013.
- BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Diário Oficial da União, Brasília, DF, 2018.
- BRASIL. Lei nº 12.965, de 23 de abril de 2014. Marco Civil da Internet. Diário Oficial da União, Brasília, DF, 2014.
- CONSELHO FEDERAL DE MEDICINA. Resolução CFM nº 1.821/2007. Normas técnicas para digitalização e uso dos sistemas informatizados para a guarda e manuseio dos prontuários dos pacientes. Brasília: CFM, 2007.
- OWASP FOUNDATION. OWASP Top Ten 2021. Disponível em: <https://owasp.org/www-project-top-ten/>. Acesso em: jun. 2026.
- FLASK. Flask Documentation (3.x). Disponível em: <https://flask.palletsprojects.com>. Acesso em: jun. 2026.